Elina Chin - 000910074

Recommendation:
Implement Secure Data Encryption for all user-sensitive data, including purchase logs, budgets, and saved amounts, both at rest and in transit. Additionally, integrate multi-factor authentication (MFA) for account access.

Why this recommendation was chosen:

1. Encryption ensures that user data cannot be easily accessed if the app's database or network is compromised. Financial data, like as budgets, purchases, and savings, is sensitive and could be exploited if not protected.
2. MFA provides an extra layer of security beyond passwords, mitigating risks from weak or stolen credentials.

Who benefits from the recommendation?

- End-users: Protects their sensitive financial data from unauthorized access or theft.
- Developers/Company: Reduces liability and improves user trust by safeguarding data.
- Encryption Best Practices: OWASP Data Protection
- MFA Best Practices: NIST Authentication Guidelines

When should this recommendation be implemented?

- Encryption: High priority and should be implemented immediately since it addresses the critical risk of data breaches.
- MFA: Important but can be phased in to the app .

Why does the app need this recommendation?

- Financial apps are common targets due to the sensitive nature of the data involved.
- Without encryption, user data (such as budgets, spending patterns, or savings) could be exposed if the database is compromised.
- Without MFA, accounts are more susceptible to unauthorized access, particularly if users reuse weak passwords.

How can this recommendation be applied?

1. Data Encryption

   - Use AES (Advanced Encryption Standard) for data at rest.
   - Use HTTPS and TLS for encrypting data in transit.
   - Ensure sensitive data is encrypted at the application layer before storage.
2. MFA
   - Add MFA to the login process using time-based one-time passwords (TOTP) or push notifications via an authentication app (e.g., Google Authenticator).
   - Integrate MFA options via libraries or APIs like Firebase Authentication or Auth0 for feasibility.

Feasibility:

- Encryption: High feasibility with modern libraries such as OpenSSL or Bcrypt for password hashing and secure storage.
- MFA**:** Moderate feasibility, especially because Firebase is used to authenticate.

By prioritizing encryption and MFA, the app ensures that user data remains secure and instills trust among users while adhering to best practices for financial data security.